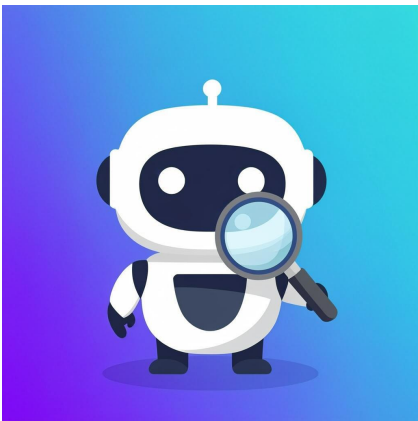


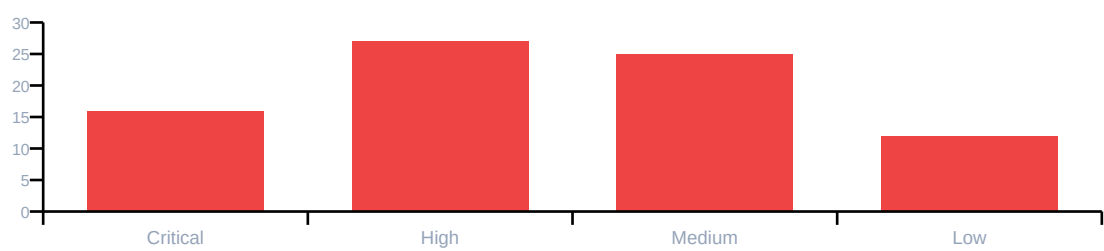


NOTJUST Watr E-Commerce Platform

Generated: 10 August 2026

Scan Summary

Total Bugs	Critical	High	Medium	Low
80	16	27	25	12



Methods: Static Code Analysis | OWASP Security Audit | Component Testing

Interactive Report Preview



80

Total Bugs Found

16

CRITICAL

27

HIGH

25

MEDIUM

12

LOW

Bug Distribution by Category



Top Buggy Components

AdminPanel	21
ProductDetailPage	14
Orders API	5
CheckoutView	5
ProductLearningModule	4
API Utils	3
Auth API	3
AuthRegister	3



16 Critical Security Vulnerabilities Detected

Unsalted SHA-256 password hashing, forgeable session tokens, client-controlled pricing, IDOR on orders, and XSS via document.write require immediate attention before production deployment.

Executive Summary

A comprehensive deep code review was performed across the entire NOTJUST Watr e-commerce platform, covering 15 application components, 49 UI components (shadcn/ui), 37 API routes, and the Zustand store. A total of 80 bugs were identified, with 16 Critical and 27 High severity issues requiring immediate attention.

Critical Security Findings

The most severe findings are security vulnerabilities: unsalted SHA-256 password hashing allows rainbow table attacks, forgeable base64 session tokens enable authentication bypass, client-controlled pricing permits arbitrary price manipulation, and IDOR vulnerabilities expose all user orders. These must be fixed before any production deployment.

Component Health Overview

Component	Bugs	Worst
AdminPanel	14	Critical
ProductDetailPage	10	Critical
CheckoutView	4	Critical
AuthWhatsAppOtpLogin	2	Critical
AuthRegister	2	Critical
Orders API	3	Critical
Auth API	2	Critical
API Utils	3	Critical
LearningModule	4	High
ProfilePage	2	High
LandingPage	4	High
SiteFooter	3	Medium
App Store	3	Medium
Data Service	2	Critical

Latest Change: "About This Product" Half-Content Display

The "About This Product" section was modified to show approximately half the content initially with a "View More" button to expand if more content exists. The truncation logic finds natural sentence/word breaks near the midpoint rather than arbitrary line clamping.

Working Correctly

- + Truncation at ~50% for long descriptions (>200 chars)
- + View More / View Less toggle functions correctly
- + Sentence-end detection finds natural breaks near midpoint
- + Short descriptions (<200 chars) show fully without toggle
- + Ellipsis (...) appended to truncated text

Issues Found

PDP-6: Aggressive Cutoff for Barely-Long Text

201-char description cut to ~100 chars at midpoint. Users see very little content before View More. Use fixed truncation target of ~180 chars instead of midpoint.

PDP-7: Truncation Only Searches Forward

Only searches 80 chars forward from midpoint for sentence break. Misses better breaks that exist before midpoint. Search backward first, then forward.

PDP-3: descExpanded Not Reset on Product Change

State persists when navigating to a different product, so new products description shown fully expanded. Add `useEffect` to reset on `selectedProductId` change.

Critical Bugs (16)

These vulnerabilities can lead to complete system compromise, data breaches, financial loss, or application instability. They must be fixed immediately.

ID	Sev	Cat	Component	Title	Impact
SEC-1	Critical	Security	API Utils	Unsalted SHA-256 Password Hashing	Full DB compromise reveals all passwords.
SEC-2	Critical	Security	Auth API	Forgeable Session Tokens	Complete auth bypass - impersonate any user.
SEC-3	Critical	Security	Orders API	Client-Controlled Order Pricing	Customers purchase at arbitrary prices.
SEC-4	Critical	Security	Orders API	No Auth on Order Listing (IDOR)	Any user views all orders of any other user.
SEC-5	Critical	Security	Data Service	No Auth on Order Cancellation	Any user cancels any order by ID.
PDP-1	Critical	State	ProductDetailPage	Race Condition: No AbortController	Wrong product shown after rapid navigation.
PDP-2	Critical	State	ProductDetailPage	Infinite Retry Loop on Fetch Failure	Infinite loop DDOSes API.
ADM-1	Critical	State	AdminPanel	Stale Closure in Data Loading	Stale data overwrites fresh.
ADM-2	Critical	Data	AdminPanel	refreshData() Skips State	Quiz counts and scan data outdated.
ADM-3	Critical	Data	AdminPanel	Product Edit Overwrites slug	Breaks QR codes, bookmarks, SEO.
ADM-4	Critical	State	AdminPanel	navigateTo During Render	Potential infinite render loop.
ADM-5	Critical	Security	AdminPanel	XSS via document.write	Stored XSS executes arbitrary JS.
AUTH-1	Critical	Logic	AuthWhatsAppOTPLogin	Phone Un-normalized to API	OTP sent to wrong number format.
AUTH-2	Critical	Logic	AuthRegister	Phone Un-normalized in Register	Registration OTP fails for intl format.
CKO-1	Critical	Logic	CheckoutView	Tax on Pre-Discount Subtotal	Customer overcharged ~2-4%.
CKO-2	Critical	State	CheckoutView	Double-Submit on Place Order	Duplicate orders, double-charging.

Top 5 Critical Fix Details

SEC-1: Unsalted SHA-256 Password Hashing

Location: [API Utils](#)

Impact: Full DB compromise reveals all passwords.

Fix: Replace with bcrypt.hash(password, 12).

SEC-2: Forgeable Session Tokens

Location: [Auth API](#)

Impact: Complete auth bypass - impersonate any user.

Fix: Use JWTs signed with server-side secret.

SEC-3: Client-Controlled Order Pricing

Location: [Orders API](#)

Impact: Customers purchase at arbitrary prices.

Fix: Fetch real prices from DB server-side.

SEC-4: No Auth on Order Listing (IDOR)

Location: [Orders API](#)

Impact: Any user views all orders of any other user.

Fix: Verify session token matches user_id.

SEC-5: No Auth on Order Cancellation

Location: [Data Service](#)

Impact: Any user cancels any order by ID.

Fix: Include user verification headers.

High Severity Bugs (27)

These issues can cause significant security breaches, data corruption, poor user experience, or application errors. They should be addressed before the next release.

ID	Sev	Cat	Component	Title	Impact
SEC-6	High	Security	API Utils	Timing-Vulnerable Password Compare	Timing attack recovers hash.
SEC-7	High	Security	Auth API	user_id Cookie Not httpOnly	XSS = account takeover.
SEC-8	High	Security	Health API	Health Endpoint Leaks Secrets	Reconnaissance for attacks.
SEC-9	High	Security	API Utils	x-admin-key Is Security Theater	Zero security from header.
API-2	High	API	Orders API	No Auth on Order Creation	Fraudulent orders.
PDP-3	High	State	ProductDetailPage	descExpanded Not Reset on Change	New product fully expanded.
PDP-4	High	State	ProductDetailPage	quantity Not Reset on Change	Wrong quantity in cart.
PDP-5	High	Logic	ProductDetailPage	handleAddToCart Uses Wrong Variable	Buy Now click does nothing briefly.
PDP-6	High	UX	ProductDetailPage	Aggressive Cutoff for Barely-Long Text	Very little before View More.
PDP-7	High	Logic	ProductDetailPage	Truncation Only Searches Forward	Cut mid-sentence.
ADM-6	High	Logic	AdminPanel	vs ?? for learningCompleted	Wrong count at 0 completions.
ADM-7	High	API	AdminPanel	Kanban Update No Error Handling	Silent failure.
ADM-8	High	Render	AdminPanel	Blank Page on Error	Blank white page.
ADM-9	High	Form	AdminPanel	Gender Select No Empty Option	Invalid Select state.
ADM-11	High	Form	AdminPanel	Zero Values Show Empty	Cannot set price to 0.
ADM-12	High	Logic	AdminPanel	Quiz Reorder Crosses Videos	Quiz moves to wrong video.
ADM-13	High	Security	AdminPanel	x-admin-key Not Real Auth	Any user calls admin APIs.
AUT-3	High	Security	AuthRegister	No OTP ID in Registration	Unverified contact registration.
AUT-4	High	UX	AuthLogin	Keep me signed in Non-Functional	Checkbox has zero effect.
CKO-3	High	Logic	CheckoutView	Total Can Go Negative	Negative order total.
PRF-1	High	Security	ProfilePage	Change Password Allows Empty	Session hijack = password change.
PRF-2	High	State	ProfilePage	No AbortController for Fetches	Memory leaks.
PLM-1	High	State	LearningModule	Infinite Loading Spinner	Stuck on loading forever.
PLM-2	High	State	LearningModule	Stale videoProgress Closure	Video resumes at wrong position.
PLM-3	High	State	LearningModule	Race in saveVideoProgress	Progress silently lost.
PLM-4	High	Logic	LearningModule	handleSeek No Clamp 0-100	Progress shows >100%.
LP-1	High	UX	LandingPage	Badge Position Overlap	Unreadable overlapping text.

Medium Severity Bugs (25)

These issues affect usability, code quality, or may cause minor errors under specific conditions.

ID	Sev	Cat	Component	Title	Impact
PDP-8	Medium	UX	ProductDetailPage	Share Cancel Falls to Clipboard	Unwanted clipboard write.
PDP-9	Medium	State	ProductDetailPage	copied State Never Rendered	Unnecessary re-renders.
PDP-10	Medium	State	ProductDetailPage	progressFetchKey Never Incremented	Progress never manually refreshed.
PDP-14	Medium	UX	ProductDetailPage	Flash of Wrong Learning Button	Flash for returning users.
ADM-15	Medium	State	AdminPanel	No Loading State During Save	Double-click = duplicate.
ADM-17	Medium	UX	AdminPanel	Destructive Actions Use confirm()	Inconsistent UX.
ADM-18	Medium	Logic	AdminPanel	Revenue Trend Data Fabricated	Misleading trend chart.
ADM-23	Medium	Logic	AdminPanel	CANCELLED Orders Missing Kanban	Cancelled orders invisible.
ADM-26	Medium	Logic	AdminPanel	Campaign Has No Delete	Cannot remove campaigns.
ADM-27	Medium	UX	AdminPanel	Subscriptions Read-Only	Cannot manage subscriptions.
ADM-36	Medium	UX	AdminPanel	No Pagination on Tables	Poor performance at scale.
AUTH-6	Medium	State	AuthRegister	Auto-redirect Missing Deps	Stale redirect target.
FORM-1	Medium	Form	All Auth+Checkout	No form Elements, Enter Doesnt Submit	Poor UX, a11y issue.
CART-2	Medium	Logic	CartItemCard	No Max Quantity/Stock Validation	Over-ordering possible.
CKO-4	Medium	UX	CheckoutView	Shipping Form Not Pre-Filled	Users re-type address every time.
NAV-1	Medium	Navigation	AppNavbar	No Sign Out in Mobile Menu	Must nav to Profile to logout.
LP-2	Medium	UX	LandingPage	Auto-Scroll Resumes After Manual	Carousel fights user.
LP-3	Medium	Navigation	LandingPage	Mobile Home Doesnt Scroll to Hero	Home button does nothing.
SF-1	Medium	Navigation	SiteFooter	Social Media Buttons Non-Functional	Dead buttons.
SF-2	Medium	Security	SiteFooter	window.open Without noopener	Tab-napping vulnerability.
STORE-1	Medium	Logic	App Store	Cart Key Collision (productId-only)	Cannot buy both ways.
STORE-3	Medium	State	App Store	resetForLogout Doesnt Reset All	Stale UI in new session.
API-3	Medium	API	Orders API	Order Creation Missing Item Validation	Malformed orders corrupt DB.
API-4	Medium	API	Orders API	No Stock Validation on Order	Overselling.
SEC-10	Medium	Security	Auth API	No Rate Limiting on Auth	Brute-force attacks.

Low Severity Bugs (12)

These are minor code quality issues, accessibility gaps, or anti-patterns with low immediate impact.

ID	Sev	Cat	Component	Title	Impact
PDP-15	Low	A11y	ProductDetailPage	No aria-expanded on View More/Less	Screen readers miss toggle.
PDP-18	Low	Render	ProductDetailPage	Array Index as key	Fragile if data reorders.
PDP-21	Low	UX	ProductDetailPage	Quantity with No UI Controls	Must add to cart repeatedly.
ADM-39	Low	A11y	AdminPanel	Missing ARIA Labels on Sidebar	Screen readers cant identify.
ADM-43	Low	Form	AdminPanel	Insufficient Product Validation	Invalid products created.
A11Y-1	Low	A11y	AuthPages	Privacy/Terms Non-Interactive	Cannot view policies.
AUTH-8	Low	Logic	AuthRegister	Password Strength Too Weak	Easily crackable passwords.
CKO-5	Low	Logic	CheckoutView	Online Payment Creates Orders Anyway	Orders stuck PENDING forever.
LP-7	Low	A11y	LandingPage	CTA Image Has Empty alt	Screen readers skip image.
SF-3	Low	A11y	SiteFooter	Footer Links Use button Not a	Wrong semantic role.
STORE-5	Low	Security	App Store	User Data in Plaintext localStorage	Exposure if device shared/XSS.
API-7	Low	API	Admin Users API	Search Is Case-Sensitive	Must match exact case.

Testing Methodology

Static Code Analysis

Deep review of all 15 application components, 49 UI components (shadcn/ui), 37 API routes, Zustand store, and data service. ESLint passed with zero errors.

OWASP Security Audit

Authentication, session management, IDOR, XSS, CSRF, input validation, password storage, and access control reviewed against OWASP Top 10.

Component Testing

Event handlers, state management, race conditions, form validation, accessibility, and rendering edge cases tested across all interactive components.

Bug Distribution by Category

Category	Count	Percentage
Security	16	20.0%
State	16	20.0%
Logic	16	20.0%
UX	11	13.8%
API	5	6.2%
A11y	5	6.2%
Form	4	5.0%
Navigation	3	3.8%
Data	2	2.5%
Render	2	2.5%